

2.1.11 Lesson Review

Date: 3/4/2026, 10:35:05 PM

Time Spent: 11:25

Score: 100%

Passing Score: 80%



Question 1

✓ Correct

Which of the following teams should typically be involved when coordinating AI threat modeling activities within an organization? (Select three.)

- ☐ Customer Support Team
- ☐ Marketing and Advertising Team
- ☒ Security Team ✓ Correct
- ☐ Facilities Management Team
- ☒ Application Architecture Team ✓ Correct
- ☒ Legal and Compliance Team ✓ Correct

Explanation

Security Team is a correct answer. The security team is a critical participant in AI threat modeling. They provide expertise in identifying, assessing, and mitigating security vulnerabilities and risks throughout the AI lifecycle.

Legal and Compliance Team is a correct answer. Laws, regulations, and organizational policies must be considered in AI system design. The legal and compliance team ensures all regulatory and compliance requirements are addressed and helps avoid liability issues.

Application Architecture Team is a correct answer. The architecture team understands the technical design, data flows, and integrations within the AI system. Their input is vital to map potential threats, identify sensitive areas, and implement secure system architecture.

Marketing and Advertising Team is incorrect. While marketing may communicate about AI features to users, they aren't central to threat modeling and do not analyze risks, vulnerabilities, or compliance issues as part of this process.

Customer Support Team is incorrect. Customer support assists users with operational or technical problems, but does not manage or secure AI architecture or address threats to the system in the threat modeling context.

Facilities Management Team is incorrect. Facilities management is responsible for the physical environment (e.g., office buildings, utilities) and does not have a role in the architecture, security, or compliance of AI systems.

Related Content

-  2.1.3 Utilizing AI Threat Resources
-  2.1.5 Prerequisites for Performing AI Threat Modeling
-  2.1.6 Process of AI Threat Modeling
-  2.1.8 AI Threat Modeling Frameworks

resources\questions\q_prerequisites_for_performing_ai_threat_modeling_02.question.xml

A social media company has developed an AI-driven content moderation tool and has gone through threat modeling. The team has already identified, categorized, and rated the severity of several threats, such as data leakage and model manipulation.

What should the team do NEXT to satisfy Step 5 of the AI threat modeling process?

The team repeats risk assessment interviews with developers and testers, delaying documentation until every internal stakeholder has been consulted.

- The team compiles a detailed report summarizing all identified threats, their severity, and provides recommendations for mitigation, then shares this information with relevant stakeholders. ✓ Correct

The team immediately starts remediating all identified threats, applying standard fixes, but does not formally document the analysis or communicate it to stakeholders.

The team goes back to review available AI threat modeling frameworks to ensure none were missed during their initial analysis.

Explanation

The team compiles a detailed report summarizing all identified threats, their severity, and provides recommendations for mitigation, then shares this information with relevant stakeholders is the correct answer. This answer directly reflects Step 5 – Generate a report with the threats identified. This step is essential for enabling risk-informed decisions and ongoing collaboration.

The team goes back to review available AI threat modeling frameworks to ensure none were missed during their initial analysis is incorrect. This action relates to Step 2 of the process. Once threats have already been identified and analyzed, the next step should be to formalize and communicate the outcomes—not to revisit framework selection.

The team immediately starts remediating all identified threats, applying standard fixes, but does not formally document the analysis or communicate it to stakeholders is incorrect. While remediation is important, skipping the reporting step can lead to miscommunication, missed priorities, and lack of traceability. Documentation is crucial for tracking progress, collaboration, and accountability. Step 5 emphasizes the importance of producing a report before taking remediation action.

The team repeats risk assessment interviews with developers and testers, delaying documentation until every internal stakeholder has been consulted is incorrect. The correct process is to generate and distribute the report soon after threat analysis, enabling feedback and action to occur in a structured, timely manner. Waiting postpones risk mitigation and may introduce unnecessary confusion.

Related Content

-  2.1.3 Utilizing AI Threat Resources
-  2.1.5 Prerequisites for Performing AI Threat Modeling
-  2.1.6 Process of AI Threat Modeling
-  2.1.8 AI Threat Modeling Frameworks

resources\questions\q_processing_of_ai_threat_modeling_04.question.xml

A healthcare provider uses an AI-powered chatbot to assist patients with symptom checking and scheduling appointments. The AI-generated content includes health suggestions, possible conditions, and appointment times, all based on user-submitted information, such as symptoms and medical history.

Since these outputs influence patient decision-making and sensitive data handling, you are tasked as an AI threat modeler to help the organization minimize the risks associated with the use of AI-generated information.

Which of the following actions BEST applies AI threat modeling principles to the AI-generated content used by this chatbot?

Regularly update the AI model, trusting that newer versions will automatically resolve any issues related to misinformation or bias in the chatbot outputs, without verifying individual content provided to patients.

Configure the AI chatbot to generate detailed reports, including all patient information, explanation for the suggested conditions, and scheduling data, and send these automatically to the patient and a hospital-wide distribution list to facilitate broader review.

Assume that AI-generated outputs are inherently reliable because of the robust training data and allow all chatbot results to be presented directly to patients without any further review, ensuring a quick patient experience.

Implement post-processing validation and filtering on the AI-generated output to verify that health suggestions and

- appointment recommendations are accurate, unbiased, and do not expose confidential patient information before showing them to patients. ✓ Correct

Explanation

Implementing post-processing validation and filtering on the AI-generated output to verify that health suggestions and appointment recommendations are accurate, unbiased, and do not expose confidential patient information before showing them to patients is the correct answer. This action introduces a validation layer to mitigate risks such as incorrect health suggestions, bias, or exposure of confidential patient info. This comply with policies, support regulatory and ethical requirements, and protect patient safety and privacy.

Assuming that AI-generated outputs are inherently reliable because of the robust training data and allowing all chatbot results to be presented directly to patients without any further review is incorrect. Without validation, there is a risk of misinformation, privacy breaches, and potentially harmful suggestions reaching patients. AI threat modeling emphasizes the need for critical evaluation of automated outputs, not unquestioning acceptance.

Regularly updating the AI model, trusting that newer versions will automatically resolve any issues related to misinformation or bias in the chatbot outputs, without verifying individual content is incorrect. While updating models is important for improvement, it does not guarantee prevention of inappropriate or unsafe content. New models may also introduce additional risks. Without validating the outputs, you cannot assure patient safety or data protection.

Configuring the AI chatbot to generate detailed reports, including all patient information, explanation for the suggested conditions, and scheduling data, and sending these automatically to the patient and a hospital-wide distribution list is incorrect. This practice increases the risk of data leaks, breaches of patient confidentiality, and non-compliance with regulations such as HIPAA. Threat modeling in healthcare stresses data minimization, confidentiality, and distributing sensitive information only to those with a legitimate need.

Related Content

-  2.1.3 Utilizing AI Threat Resources
-  2.1.5 Prerequisites for Performing AI Threat Modeling
-  2.1.6 Process of AI Threat Modeling
-  2.1.8 AI Threat Modeling Frameworks

resources\questions\q_prerequisites_for_performing_ai_threat_modeling_06.question.xml

During the design phase of an AI application that analyzes uploaded images and personal data, a team member suggests including AI threat modeling as part of the Secure Software Development Life Cycle (SDLC).

Which of the following actions directly applies an AI threat modeling step to this use case?

Choose random open-source machine learning models for the project and ensure that all team members sign a compliance checklist agreeing to use secure coding practices.

Deploy the AI application into the production environment and monitor real-time user activities to identify suspicious behavior and later update security policies.

- Evaluate how the AI application collects, stores, and processes uploaded images and personal data, then identify potential threats such as data poisoning, model extraction, and access control misconfigurations. ✓ Correct

Assign the AI development team to review generic cybersecurity guidelines and ensure that front-end input forms use CAPTCHA to prevent automated spam bots, while postponing any specialized analysis of AI threats until after the application is finished.

Explanation

Evaluating how the AI application collects, stores, and processes uploaded images and personal data, then identifying potential threats such as data poisoning, model extraction, and access control misconfigurations, is the correct answer. This is an application of the AI threat modeling. Including this assessment during the SDLC's design phase aligns perfectly with recommended best practices for securing AI systems.

Deploying the AI application into the production environment and monitoring real-time user activities to identify suspicious behavior and later update security policies is incorrect. Monitoring user activity in production is not an example of applying AI threat modeling during the design phase of the SDLC. Threat modeling should occur early, before deployment, so that risks can be anticipated and mitigated proactively. Reacting to security incidents after deployment is not aligned with threat modeling best practices, and leaves the application vulnerable in its initial launch period.

Assigning the AI development team to review generic cybersecurity guidelines and ensure that front-end input forms use CAPTCHA to prevent automated spam bots, while postponing any specialized analysis of AI threats until after the application is finished, is incorrect. This approach focuses on generic web security controls, not AI-related risks. Moreover, postponing specialized AI threat analysis until after the application is finished misses the critical window for effective threat modeling during the design phase. Failure to do so early in the SDLC can result in foundational vulnerabilities that are costly or impossible to fix later.

Choosing random open-source machine learning models for the project and ensuring that all team members sign a compliance checklist agreeing to use secure coding practices is incorrect. These actions are generally good practice, but are not AI threat modeling. Threat modeling requires evaluating how the models and data are used in the application. Without a step-by-step examination of how threats might arise based on the specifics of the data and model integration, this action misses the core purpose of AI threat modeling.

Related Content

resources\questions\q_introduction_to_ai_threat_modeling_03.question.xml

A research team is developing a new machine learning algorithm intended for use in autonomous vehicles. As part of their threat modeling process, the team wants to ensure they are aware of the latest research on AI vulnerabilities that could impact their deployment.

How should the team use arXiv to help them address this need?

Use arXiv to identify established standards and regulations for AI system deployment, ignoring preliminary research or cutting-edge findings.

- Regularly search arXiv for recently published papers on AI security vulnerabilities relevant to autonomous vehicles, and incorporate findings and suggested defenses into their threat modeling process. ✓ Correct

Depend on arXiv to notify them automatically about every new vulnerability discovered in the field of autonomous vehicles, ensuring their system remains fully secure.

Upload their machine learning algorithm to arXiv and request that the research community peer-review it for potential vulnerabilities before deploying it.

Explanation

Regularly searching arXiv for recently published papers on AI security vulnerabilities relevant to autonomous vehicles, and incorporating findings and suggested defenses into their threat modeling process is the correct answer. arXiv is an open-access repository where researchers publish the latest scientific papers, including new AI security threats and defenses. By searching arXiv, the team can stay informed and integrate the latest knowledge and recommendations into their own risk assessments and threat models.

Uploading their machine learning algorithm to arXiv and request that the research community peer-review it for potential vulnerabilities before deploying it is incorrect. While the community can provide feedback on uploaded papers, there is no guarantee of thorough peer review or targeted vulnerability discovery for specific submissions, especially prior to publication or real-world deployment.

Using arXiv to identify established standards and regulations for AI system deployment, ignoring preliminary research or cutting-edge findings, is incorrect. Relying solely on arXiv for established standards and regulations would lead the team to miss out on the platform's primary value. Regulations may be slow to evolve. Incorporating emerging research allows the team to anticipate and address threats sooner rather than waiting for official industry guidelines.

Depending on arXiv to notify them automatically about every new vulnerability discovered in the field of autonomous vehicles is incorrect. arXiv does not provide this service. New vulnerabilities may also not always be directly applicable to all users' needs. Effective risk management depends on actively searching for and reviewing literature, not passively relying on automatic notifications or assuming full coverage of all developments.

Related Content

-  2.1.3 Utilizing AI Threat Resources
-  2.1.5 Prerequisites for Performing AI Threat Modeling
-  2.1.6 Process of AI Threat Modeling
-  2.1.8 AI Threat Modeling Frameworks

resources\questions\q_utilizing_ai_threat_resources_10.question.xml

A logistics company has finished threat modeling for its new AI-powered route optimization platform. They have already gathered system information, chosen a framework, identified threats, rated their severity, and shared a mitigation report with all relevant stakeholders.

What should the team do NEXT to satisfy Step 6 of the AI threat modeling process?

The team reviews only legal compliance requirements for data protection, postponing technical evaluations until after deployment.

The team revisits which AI modeling frameworks to use and considers switching their approach to threat modeling, even though the initial report is complete.

The team holds a meeting with executives to discuss non-technical business goals for the AI platform and schedules marketing promotions for its launch.

The team conducts ongoing security assessments throughout the software development life cycle (SDLC),

- using penetration testing and code reviews to validate that mitigations for identified AI risks are actually effective.

✔ Correct

Explanation

The team conducts ongoing security assessments throughout the software development life cycle (SDLC), using penetration testing and code reviews to validate that mitigations for identified AI risks are actually effective is the correct answer. This answer aligns exactly with Step 6 – Security Assessments as described in the document. Security assessments, such as code reviews and penetration tests, provide continuous validation and feedback, helping to maintain security and resilience as the application evolves.

The team holds a meeting with executives to discuss non-technical business goals for the AI platform and schedules marketing promotions for its launch is incorrect. This answer is unrelated to the security assessment step. While executive input and business planning are important, they do not address the ongoing technical validation of security controls as required by Step 6 in the AI threat modeling process.

The team reviews only legal compliance requirements for data protection, postponing technical evaluations until after deployment is incorrect. While legal compliance is necessary, Step 6 emphasizes proactive, technical security assessments. Postponing testing and only focusing on legal aspects ignores the need to validate that security mitigations are actively working and does not meet the requirements of this step in the threat modeling process.

The team revisits which AI modeling frameworks to use and considers switching their approach to threat modeling, even though the initial report is complete is incorrect. Reconsidering frameworks might be useful if the context or system changes significantly, but at this stage, after threat identification and reporting, the next step is security validation.

Related Content

-  2.1.3 Utilizing AI Threat Resources
-  2.1.5 Prerequisites for Performing AI Threat Modeling
-  2.1.6 Process of AI Threat Modeling
-  2.1.8 AI Threat Modeling Frameworks

resources\questions\q_processing_of_ai_threat_modeling_05.question.xml

An organization integrates a large language model (LLM) into its internal ticketing system so employees can automate support tasks, such as resetting passwords and modifying user account permissions. The LLM is configured with broad access to backend systems and is not restricted from making sensitive changes.

During a security assessment, you are asked to identify the primary vulnerability this setup introduces, as defined by the OWASP Top 10 for LLMs.

Which OWASP Top 10 LLM vulnerability BEST describes the risk presented by allowing the LLM broad and unregulated access to backend resources?

● LLM06: Excessive Agency ✓ Correct

LLM04: Data and Model Poisoning

LLM01: Prompt Injection

LLM10: Unbounded Consumption

Explanation

LLM06: Excessive Agency is the correct answer. Excessive Agency refers to giving an LLM too much control over tools, systems, or workflows—allowing it to perform sensitive or unintended actions due to over-permissioned access. In the scenario, the LLM can make broad, sensitive changes (like password resets and permission modifications) without restriction, which directly maps to Excessive Agency.

LLM01: Prompt Injection is incorrect. Prompt Injection attacks involve manipulating the prompts or instructions given to the LLM in order to change its behavior or leak information. While dangerous, this is unrelated to the LLM being granted excessive permissions or access to backend systems.

LLM04: Data and Model Poisoning is incorrect. Data and Model Poisoning describes the corruption of a model's training data or fine-tuning process, causing it to learn harmful or biased behaviors. In this scenario, the risk isn't about how the LLM was trained or fine-tuned.

LLM10: Unbounded Consumption is incorrect. Unbounded Consumption addresses risks associated with lack of rate-limiting, where LLM queries or automated actions can overwhelm backend resources, leading to denial of service or unnecessary operational costs. The scenario's primary risk is not overuse of resources.

Related Content

resources\questions\q_ai_threat_modeling_frameworks_04.question.xml

Question 8

✓ Correct

Which of the following are risk domains classified by the Domain Taxonomy in the MIT AI Risk Repository? (Select three.)

- ☐ Financial Accounting Standards
- ☐ Wireless Communication Protocols
- ☒ Discrimination & Toxicity ✓ Correct
- ☐ User Interface Design Principles
- ☒ AI System Safety, Failures, & Limitations ✓ Correct
- ☐ Financial Loss Prevention
- ☒ Human-Computer Interaction ✓ Correct

Explanation

Discrimination & Toxicity is a correct answer. Discrimination & Toxicity is one of the primary risk domains listed in the MIT AI Risk Repository's Domain Taxonomy. It covers risks related to unfair bias, toxic content, and unequal treatment by AI systems.

Human-Computer Interaction is a correct answer. Human-Computer Interaction is a domain in the Domain Taxonomy. It addresses risks that arise from the way users interact with AI systems, including usability and the possibility of harmful or misleading experiences.

AI System Safety, Failures, & Limitations is a correct answer. AI System Safety, Failures, & Limitations is listed as a risk domain and focuses on operational safety, system malfunctions, resilience, and the boundaries of what AI systems can do.

User Interface Design Principles is incorrect. While user interface design may affect how users interact with AI, it is not one of the official risk domains classified in the MIT AI Risk Repository's Domain Taxonomy.

Financial Accounting Standards is incorrect. Financial Accounting Standards are not a risk domain under the Domain Taxonomy. The MIT AI Risk Repository focuses on AI-specific risks, not compliance with accounting rules.

Financial Loss Prevention is incorrect. Financial Loss Prevention is not a risk domain classified by the Domain Taxonomy in the MIT AI Risk Repository. While financial loss might be a consequence of certain risks (such as misuse or security breaches), it is not itself listed as a standalone domain in the official taxonomy. The taxonomy focuses on broader areas that affect the operation, safety, ethics, and impact of AI, rather than on specific outcomes like financial loss prevention.

Wireless Communication Protocols is incorrect. Wireless Communication Protocols are not an AI risk domain; this relates to networking technology standards, not the risk classifications for AI systems provided by the MIT AI Risk Repository.

Related Content



2.1.3 Utilizing AI Threat Resources

resources\questions\q_utilizing_ai_threat_resources_04.question.xml

Question 9

✓ Correct

Match each Large Language Model (LLM) threat from the OWASP Top 10 on the left with its correct description on the right.

Allowing crafted user inputs to override or change system-level instructions, potentially leaking data or altering LLM operations.

✓ LLM01: Prompt Injection

LLM unintentionally outputs private or confidential information learned during training, typically due to a lack of proper data filtering.

✓ LLM02: Sensitive Information Disclosure

Introducing unreviewed third-party models, plugins, or datasets, making systems vulnerable to external exploits affecting downstream components.

✓ LLM03: Supply Chain Vulnerabilities

Allowing an attacker to manipulate training or fine-tuning data, altering future model behavior, creating biases, or delivering harmful content.

✓ LLM04: Data and Model Poisoning

Failing to verify or filter LLM outputs, potentially resulting in unintended code execution, security flaws, or exposure to embedded threats.

✓ LLM05: Improper Output Handling

Granting LLMs too much control or permission, leading to unauthorized tasks or misuse of privileges.

✓ LLM06: Excessive Agency

Explanation

The following are the correct matches for the Large Language Model (LLM) threats from the OWASP Top 10:

1. **LLM01: Prompt Injection.** Allowing crafted user inputs to override or change system-level instructions, potentially leaking data or altering LLM operations. Prompt injection is when malicious input allows a user to override or change system instructions, a core risk in LLMs. This can change LLM behavior or cause leaks.
2. **LLM02: Sensitive Information Disclosure.** LLM unintentionally outputs private or confidential information learned during training, typically due to a lack of proper data filtering. LLMs may reveal private information if their training data includes sensitive content, especially when outputs are not filtered for confidential material.
3. **LLM03: Supply Chain Vulnerabilities.** Introducing unreviewed third-party models, plugins, or datasets, making systems vulnerable to external exploits affecting downstream components. Integrating third-party components without security checks can allow vulnerabilities to infiltrate systems, justifying the need for supply chain risk management.
4. **LLM04: Data and Model Poisoning.** Allowing an attacker to manipulate training or fine-tuning data, altering future model behavior, creating biases, or delivering harmful content. Attackers can manipulate training or fine-tuning data, which alters the model's future predictions and can introduce harmful biases or errors.
5. **LLM05: Improper Output Handling.** Failing to verify or filter LLM outputs, potentially resulting in unintended code execution, security flaws, or exposure to embedded threats. Outputs from LLMs, if not validated, may include unsafe commands, code, or data, potentially causing issues like script injection or functionality abuse.
6. **LLM06: Excessive Agency.** Granting LLMs too much control or permission, leading to unauthorized tasks or misuse of privileges. Allowing LLMs too many privileges or permissions can let them trigger unauthorized or unintended actions, becoming a security and operational risk.

Related Content

resources\questions\q_ai_threat_modeling_frameworks_01.question.xml

When evaluating the shift from traditional software applications to AI-driven systems, which of the following BEST explains why AI threat modeling is essential in ensuring organizational security and compliance?

AI threat modeling is only important if the organization is using open-source AI models, as proprietary models are less likely to be attacked or misconfigured.

AI applications introduce unique risks, such as data

- poisoning, model extraction, and inadvertent disclosures, ✓ Correct and need guidelines for organizational compliance.

AI threat modeling is mainly used to document traditional system vulnerabilities, like SQL injection and cross-site scripting, since those are common risks AI systems face.

AI threat modeling is mainly used to reduce operational costs associated with training models, as security and compliance play little role in the threat modeling of AI systems.

Explanation

AI applications introduce unique risks, such as data poisoning, model extraction, and inadvertent disclosures, and need guidelines for organizational compliance is the correct answer. This answer emphasizes the new, unique threats AI presents—beyond what traditional applications face—and recognizes that specialized threat modeling is crucial to identify and mitigate those issues. The answer also includes organizational compliance, which is a key concern when handling potentially sensitive data with AI systems.

AI threat modeling is mainly used to document traditional system vulnerabilities, like SQL injection and cross-site scripting, since those are common risks AI systems face is incorrect. This is incorrect because AI systems pose unique risks. Limiting threat modeling to conventional threats disregards the emergence of AI-specific vulnerabilities.

AI threat modeling is only important if the organization is using open-source AI models, as proprietary models are less likely to be attacked or misconfigured is incorrect. This option is misleading. Limiting concern to just open-source models ignores the reality that proprietary models are also vulnerable. Both systems can have vulnerabilities, supply-chain risks, or be targets for misconfiguration, data poisoning, or bias.

The main reason for AI threat modeling is to reduce operational costs associated with training models is incorrect. Reducing costs is not the main purpose of AI threat modeling. AI threat modeling emphasizes identifying vulnerabilities and ensuring compliance, rather than cost reduction.

Related Content

resources\questions\q_introduction_to_ai_threat_modeling_05.question.xml